SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA1410 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.
6. While testing a web application, you find a vulnerability that could allow you to access other clients' data hosted on the same shared server. This is outside your contracted scope. What do you do, and how does this scenario illustrate the limits of ethical hacking engagements?
7. A junior tester on your team wants to use automated exploitation tools without fully understanding what they do, "because it's faster." Using this scenario, explain the risks of tool-dependent hacking and the professional standards expected of an ethical hacker.

8. Your client's competitor secretly offers you money to share findings from a penetration test you conducted for the client. Analyze this scenario in terms of professional ethics, confidentiality, and potential legal consequences.
9. A 16-year-old finds a flaw in their school's grading portal and quietly emails the administration instead of exploiting it. Classify this individual using standard hacker categorizations and justify your reasoning.
10. An employee, angry after being denied a promotion, uses their legitimate system access to leak internal documents to a journalist. Is this "hacking"? Analyze the actor's classification, motive, and the ethical/legal implications.
11. A security researcher publicly releases a working exploit for a vulnerability before the vendor has issued a patch, arguing that public pressure is the only way to force a fix. Discuss whether this qualifies as ethical hacking, and where this person falls on the hacker spectrum.
12. A nation-state-sponsored group breaches a hospital's systems to disrupt operations during a geopolitical conflict. Analyze this scenario across the categories of hacker types and explain why classification matters for response and law.
13. A person with no malicious intent scans random IP addresses on the internet "just to see what's out there" without permission. Argue both sides: is this person a "grey hat," and what ethical line have they crossed, if any?
14. Two people independently discover the same zero-day vulnerability. One reports it to the vendor; the other sells it on a dark web marketplace. Compare and contrast their classifications, motivations, and the consequences each might face.
15. A company employee is asked by management to secretly access a colleague's email account to gather evidence of misconduct, using company-owned credentials. Is this employee acting as an "ethical hacker"? Defend your position.
16. An AI-powered bot automatically probes IoT devices for default passwords and reports vulnerable devices to a public database without owner consent. Analyze whether the creator of this bot fits any traditional hacker classification, and what new categories might be needed.
17. You're performing an authorized penetration test and discover evidence that an employee of the client company is engaged in a separate, unrelated crime (e.g., embezzlement) unrelated to your scope. What are your ethical obligations, and how do they interact with your contractual scope?
18. A client asks you to test only certain departments, but you strongly suspect the departments excluded from scope contain the greatest security risk (possibly deliberately hidden by executives). Discuss the ethical tension between contractual boundaries and your professional duty to protect the organization.
19. During a social engineering assessment, you successfully manipulate a receptionist into revealing sensitive information by pretending to be a grieving relative of an employee. Evaluate the ethics of this pretext, considering psychological harm versus test realism.

20. You discover a vulnerability so severe that exploiting it, even briefly, could crash critical hospital patient-monitoring systems. Your contract requires "full exploitation to confirm impact." How do you ethically resolve this conflict between contractual obligation and patient safety?
21. Your firm offers a discount to clients who agree to let you reuse "anonymized" data from their penetration test in a public case study or training material. Analyze the ethical issues around consent, anonymization, and confidentiality in this business model.
22. You are asked to test the security awareness of employees by sending a phishing email that impersonates a company layoff announcement, since it's proven to get high click rates. Discuss the ethical boundaries of social engineering tests and psychological impact on staff.
23. A fellow ethical hacker on your team wants to keep a "personal copy" of exploit code and access credentials discovered during a client engagement "in case it's useful later." Analyze the ethical and professional violations in this scenario.
24. You are contracted by a company to test its systems, but during recon you realize the company's core business model itself may be operating a scam that harms consumers. Do professional ethics require you to report this, and to whom, given your role is purely technical?
25. You are hired by a US-based company to test servers that are physically hosted in another country with different (and less protective) cybersecurity laws. Analyze the jurisdictional and legal issues you must resolve before starting the engagement.
26. Midway through a penetration test, the client's CEO verbally tells you to "go ahead and test that system too," but it isn't in the signed Statement of Work. Explain the legal risks of proceeding, referencing the concept of authorization and applicable computer misuse laws.
27. You discover, during an authorized test, a backdoor that appears to have been planted by a previous (unauthorized) attacker who is still actively using it. What are your legal obligations regarding evidence handling, reporting, and potential involvement of law enforcement?
28. A client terminates your penetration testing contract mid-engagement due to a business dispute, but you still have active reverse shells and access credentials on their systems. Explain, step by step, what legal and ethical actions you must take immediately.
29. An ethical hacker signs a contract with vague scope language ("test the network") and later exploits a cloud-based third-party service integrated with the client's systems. The third party threatens legal action. Analyze where liability may fall and how proper scoping and legal documentation could have prevented this.
30. A government asks a security firm to hack into a foreign company's servers "in the national interest," without a formal legal warrant applicable across borders. Discuss the legal and ethical grey areas this creates for the hackers involved, referencing relevant legal frameworks like the Computer Fraud and Abuse Act (or equivalent).

31. You are asked to sign an NDA and a "get out of jail free" authorization letter before a physical penetration test (attempting to break into a building). During the test, local police detain you before you can produce the letter. Explain what legal protections such authorization documents provide, and their limitations in real time.
32. A company's Terms of Service prohibit "unauthorized testing" of their systems, but a security researcher argues that responsibly probing publicly accessible endpoints without causing damage should be legal under public interest research exceptions. Analyze this argument using real-world legal precedent or debate.
33. You discover a critical zero-day vulnerability in widely-used medical device software during an authorized test. The vendor is unresponsive for 90 days despite multiple attempts to contact them. Using a responsible disclosure framework, explain your next steps and justify the timeline.
34. A security researcher publicly tweets details of a vulnerability in a popular banking app within hours of discovering it, without contacting the bank first, citing "the public has a right to know." Analyze this against standard disclosure practices and the potential real-world consequences.
35. You report a vulnerability to a company through their official bug bounty program, but the company threatens legal action against you instead of paying the promised reward, claiming you "exceeded authorized scope." Discuss the disclosure and legal risks researchers face, and how to mitigate them beforehand.
36. During a coordinated disclosure process, the vendor asks you to delay public disclosure indefinitely with no fixed patch timeline, citing "business reasons" unrelated to the technical fix. As the researcher, how do you balance ethical disclosure obligations against vendor pressure?
37. You find a vulnerability affecting an open-source library used by thousands of downstream applications. Disclosing to the maintainer alone won't reach all affected parties quickly. Design a disclosure strategy that balances speed, safety, and coordination across the ecosystem.
38. A company offers you a "hush payment" larger than their bug bounty reward, on the condition you never disclose the vulnerability, even after it's patched. Analyze the ethical implications of accepting this offer versus standard responsible disclosure.
39. You discover a vulnerability while testing one client's system, but the flaw actually exists in a third-party software product used by thousands of other organizations who are not your clients. Explain your ethical and practical disclosure obligations in this multi-party scenario.
40. A rival security researcher discloses a vulnerability you found first, taking public credit, after you had already privately reported it to the vendor under an embargo. Discuss the ethical norms around disclosure credit, embargoes, and how researchers should handle disputes like this professionally.

Code of Conduct:

I **K. SRI LASYA [192472216]** *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	**Weightage**	**Level 4 – Exemplary**	**Level 3 – Proficient**	**Level 2 – Developing**	**Level 1 – Beginning**
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, wellstructured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach

Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, wellorganized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

11. Ethical Hacking and Public Release of a Security Exploit

1. Introduction

Ethical hacking is the process of identifying vulnerabilities in computer systems, applications, and networks to improve security and protect users. Ethical hackers should follow legal rules, professional responsibilities, and responsible disclosure practices.

However, conflicts may arise when a security researcher publicly releases a working exploit before the software vendor has issued a patch. The researcher argues that public pressure is the only way to force the vendor to fix the problem. In this situation, the researcher must balance transparency, public safety, professional ethics, and the risk of cyberattacks.

2. Understanding the Problem

A security researcher may discover a vulnerability in software, a website, or a computer system. A vulnerability is a weakness that attackers may exploit, while an exploit is a method or program used to take advantage of that weakness. A patch is an update that fixes the security problem.

The difficulty arises when the researcher releases a working exploit publicly before the vendor provides a patch. Although the researcher may want to encourage the vendor to take immediate action, attackers may use the published exploit to compromise vulnerable systems.

The main ethical question is whether publicly releasing the exploit qualifies as ethical hacking or whether it violates responsible security practices.

The researcher must consider the seriousness of the vulnerability, the possible harm to users, the vendor's response, and the consequences of public disclosure.

3. Ethical Responsibilities of the Security Researcher

A security researcher has several important responsibilities.

3.1 Protecting Users

The first responsibility is to protect individuals and organizations affected by the vulnerability. Releasing a working exploit before a patch is available may expose users to unauthorized access, data theft, or system damage.

The researcher should assess the possible risks before deciding to release technical information publicly.

3.2 Following Responsible Disclosure

Responsible disclosure involves informing the vendor privately and giving them a reasonable opportunity to investigate and fix the vulnerability before publishing sensitive technical details.

The researcher should normally follow this process instead of immediately releasing a working exploit.

3.3 Maintaining Professional Integrity

The researcher should act honestly, responsibly, and professionally. Although public pressure may encourage a vendor to fix a problem, the researcher should not ignore user safety to achieve that goal.

The researcher's intention to improve security is important, but the method used must also be ethically justified.

3.4 Avoiding Unnecessary Harm

Public disclosure can increase awareness and encourage faster security fixes. However, publishing a working exploit before a patch is available may also help malicious hackers attack vulnerable systems.

Therefore, the researcher should carefully decide what information can be shared and when it should be released.

4. Evaluating Whether the Action Qualifies as Ethical Hacking

The researcher's action should be evaluated using the following factors:

- **Authorization:** Did the researcher have permission to test the system?
- **User safety:** Could releasing the exploit expose users to cyberattacks?
- **Responsible disclosure:** Was the vendor informed and given a reasonable opportunity to fix the issue?
- **Public interest:** Is disclosure necessary to warn users about a serious security risk?
- **Potential harm:** Does the publication provide attackers with information that makes exploitation easier?
- **Legal responsibility:** Does the action comply with applicable laws and disclosure agreements?

If the researcher releases a working exploit without considering these risks, the action may be ethically irresponsible even if the intention is to improve security.

Therefore, this action cannot automatically be considered ethical hacking. Both the researcher's intentions and the consequences of the disclosure must be evaluated.

5. Position on the Hacker Spectrum

The hacker spectrum commonly includes three categories.

5.1 White Hat Hacker

A white hat hacker identifies vulnerabilities with proper authorization and follows ethical practices to improve security. They generally report vulnerabilities responsibly and help organizations protect their systems.

5.2 Grey Hat Hacker

A grey hat hacker may identify vulnerabilities without authorization or act outside accepted ethical practices, even when their intention is to improve security.

In this scenario, the researcher may fall into the grey hat category if they disregard responsible disclosure practices while attempting to pressure the vendor to fix the vulnerability.

5.3 Black Hat Hacker

A black hat hacker uses hacking skills for malicious purposes, such as stealing information, damaging systems, or exploiting vulnerabilities for personal gain.

A researcher who releases an exploit is not automatically a black hat hacker. The classification depends on authorization, intention, conduct, and the circumstances of the disclosure.

5.4 Classification of the Researcher

Based on the given scenario, the researcher may be considered a **grey hat hacker** because they publicly release a working exploit before a patch is available, potentially bypassing responsible disclosure practices.

However, this classification is conditional. If the researcher had authorization and followed a justified disclosure process, the classification could differ. The key issue is whether the researcher acted responsibly and minimized harm to users.

6. Balancing Public Pressure and User Safety

The researcher must balance the need to encourage the vendor to fix the vulnerability with the responsibility to protect users.

Public disclosure may help	**Public disclosure may harm**
Encourage the vendor to fix the problem	Help attackers exploit vulnerable systems

Increase public awareness	Expose sensitive information
Promote transparency and accountability	Increase the risk of cyberattacks
Prevent indefinite delays	Harm users before a patch is available

Public pressure may be justified in some circumstances, particularly when a vendor repeatedly ignores a serious vulnerability. However, releasing a working exploit is not always the safest or most effective way to achieve a fix.

The researcher should consider safer methods of escalation before publishing details that could enable attacks.

7. Steps the Researcher Should Follow

The researcher should follow these steps to handle the vulnerability responsibly.

Step 1: Identify and verify the vulnerability

Confirm the weakness and assess its severity and possible impact on users.

Step 2: Notify the vendor privately

Provide evidence of the vulnerability and explain the security risks.

Step 3: Request a reasonable patch deadline

Ask the vendor for a clear remediation timeline and regular progress updates.

Step 4: Evaluate the vendor's response

Consider whether the vendor is making genuine progress or delaying the fix without a valid reason.

Step 5: Escalate the issue if necessary

If the vendor ignores the problem, contact an appropriate security organization, coordinated disclosure program, or relevant reporting authority.

Step 6: Consider responsible public disclosure

If public disclosure becomes necessary, provide appropriate warnings and risk information while avoiding unnecessary exploit details that could help attackers.

This approach encourages accountability while reducing the risk of harm to affected users.

8. Importance of Ethical Hacking

Ethical hacking plays an important role in improving cybersecurity.
Its major benefits include:

1. **Improved security:** Identifies weaknesses before they cause serious damage.
2. **User protection:** Helps protect sensitive information and computer systems. 3. **Responsible disclosure:** Gives vendors an opportunity to fix vulnerabilities.
4. **Accountability:** Encourages organizations to address security problems.
5. **Reduced cyberattacks:** Helps reduce the risk of exploitation.
6. **Professional integrity:** Encourages researchers to follow ethical and legal practices.

Responsible disclosure helps balance public awareness with the need to protect vulnerable systems.

9. Ethical Principles Involved

The situation involves several important ethical principles.

- **Responsibility:** The researcher must consider the consequences of releasing the exploit.
- **Beneficence:** The researcher should aim to improve security and protect users.
- **Non-maleficence:** The researcher should avoid unnecessarily increasing the risk of harm.
- **Transparency:** Security risks should be communicated appropriately.
- **Accountability:** The researcher and vendor should take responsibility for their actions.
- **Professional integrity:** Decisions should be based on evidence, ethics, and user safety.

These principles help determine whether the researcher's actions are ethically justified.

10. Conclusion

A security researcher who publicly releases a working exploit before the vendor issues a patch may intend to improve security by creating public pressure. However, this action can expose users to serious cyberattacks and cannot automatically be considered ethical hacking.

The researcher may fall into the grey hat category if they disregard accepted disclosure practices, although the final classification depends on authorization and the circumstances. The best approach is to notify the vendor, request a reasonable patch deadline, escalate the issue when necessary, and disclose information responsibly.

Ultimately, ethical hacking should prioritize user safety, professional integrity, and improved security while balancing transparency and accountability.